

VENDOR SCORECARD • 33 QUESTIONS

The Agentic AI SOC Vendor Scorecard

Thirty-three questions across seven pillars that separate a production AI SOC from an LLM chatbot bolted onto a legacy SIEM — scored so you can compare platforms on evidence, not on the demo.

7

scoring pillars

33

questions

0-66

total score range

1

page per vendor

How to score

For each question, mark the vendor **Red (0)** if they dodge or fail it, **Partial (1)** if the answer is incomplete, or **Green (2)** if they meet it with evidence. Total per vendor on the tally page. Anything a vendor won't show you live or put in writing scores Red.

PILLAR 1 / 7 • WEIGHT 25%

Detection Accuracy

TRIAGE PHASE AI that can't reliably find threats makes everything downstream irrelevant. Push past lab benchmarks for production proof.

1 What is the documented false-positive rate?

SCORE 0 Red 1 Partial 2 Green

2 What MITRE ATT&CK coverage can they prove, not claim?

SCORE 0 Red 1 Partial 2 Green

3 Does detection logic adapt to your environment?

SCORE 0 Red 1 Partial 2 Green

4 Can they show alert-to-triage time on production data?

SCORE 0 Red 1 Partial 2 Green

5 How does the system handle novel, unseen threats?

SCORE 0 Red 1 Partial 2 Green

PILLAR 2 / 7 • WEIGHT 20%

Investigation Logic

INVESTIGATION PHASE Non-deterministic AI that gives different answers to the same alert is a compliance problem. Test for consistency and human override.

6 Are investigations deterministic or non-deterministic?

SCORE

0 Red

1 Partial

2 Green

7 Replay the same alert — do you get the same output?

SCORE

0 Red

1 Partial

2 Green

8 Is context collected across identity, endpoint, cloud, and SaaS?

SCORE

0 Red

1 Partial

2 Green

9 Is the reasoning chain visible and auditable?

SCORE

0 Red

1 Partial

2 Green

10 Can a senior analyst override AI conclusions at every step?

SCORE

0 Red

1 Partial

2 Green

PILLAR 3 / 7 • WEIGHT 20%

Autonomy Guardrails

RESPONSE PHASE This is the trust question. Autonomous action without guardrails is how an AI takes down production. Confirm the brakes exist.

11 Is written pre-authorization required before autonomous actions?

SCORE

0 Red

1 Partial

2 Green

12 Are response actions scoped by asset class?

SCORE

0 Red

1 Partial

2 Green

13 Can you define per-action approval workflows?

SCORE

0 Red

1 Partial

2 Green

14 Is there a kill switch to halt all autonomous actions?

SCORE

0 Red

1 Partial

2 Green

15 Does it verify with affected users before containment?

SCORE

0 Red

1 Partial

2 Green

PILLAR 4 / 7 • WEIGHT 20%

Integration Depth

CROSS-CUTTING The most expensive trap: a platform that replaces your stack instead of layering on it. Confirm you keep ownership.

16 How many tools does it integrate with natively?

SCORE 0 Red 1 Partial 2 Green

17 Does it replace your SIEM/EDR, or layer on top?

SCORE 0 Red 1 Partial 2 Green

18 Can integration complete in under 30 days?

SCORE 0 Red 1 Partial 2 Green

19 Does it support on-prem, cloud, and hybrid?

SCORE 0 Red 1 Partial 2 Green

20 Do you retain ownership of logs, rules, and AI data?

SCORE 0 Red 1 Partial 2 Green

PILLAR 5 / 7

Explainability & Compliance

GOVERNANCE If the AI can't explain a decision in writing, it won't survive an audit. Get audit-readiness in the contract.

21 Does every AI action produce a human-readable explanation?

SCORE 0 Red 1 Partial 2 Green

22 Can reports be exported for SOC 2, HIPAA, ISO 27001 audits?

SCORE 0 Red 1 Partial 2 Green

23 Is there a complete audit trail of decisions and overrides?

SCORE 0 Red 1 Partial 2 Green

24 Is compliance evidence collection included, or billed extra?

SCORE 0 Red 1 Partial 2 Green

PILLAR 6 / 7 • WEIGHT 15%

Pricing & TCO

COMMERCIAL Opaque pricing hides per-GB overages and onboarding meters. The vendors who can publish numbers usually do.

25 Is pricing published per-endpoint/month?

SCORE 0 Red 1 Partial 2 Green

26 Are there hidden fees for onboarding, tuning, or compliance?

SCORE 0 Red 1 Partial 2 Green

27 What is 3-year TCO including SIEM, analysts, and licensing?

SCORE 0 Red 1 Partial 2 Green

28 Does the contract include data portability?

SCORE 0 Red 1 Partial 2 Green

PILLAR 7 / 7

AI Authenticity

VALIDATION Separates production AI from an LLM chatbot bolted onto a legacy SIEM. Make them prove it live.

29 Can you observe the AI's workflow in real time?

SCORE

0 Red

1 Partial

2 Green

30 Has the vendor published independent benchmarks?

SCORE

0 Red

1 Partial

2 Green

31 Does the AI produce different outputs for the same input?

SCORE

0 Red

1 Partial

2 Green

32 Can they run a purple-team exercise during evaluation?

SCORE

0 Red

1 Partial

2 Green

33 Is this production AI, or an LLM chatbot on a legacy SIEM?

SCORE

0 Red

1 Partial

2 Green

TALLY

Score the vendor

Add the scores from all 33 questions (0-2 each) for a total out of 66. One column per vendor.

Pillar	Questions	Max	Vendor A	Vendor B	Vendor C
1 · Detection Accuracy	Q1-Q5	10			
2 · Investigation Logic	Q6-Q10	10			
3 · Autonomy Guardrails	Q11-Q15	10			
4 · Integration Depth	Q16-Q20	10			
5 · Explainability & Compliance	Q21-Q24	8			
6 · Pricing & TCO	Q25-Q28	8			
7 · AI Authenticity	Q29-Q33	10			
Total		66			

0-34

High risk. Gaps in the areas that cost most during an incident or audit.

35-49

Gaps exist. Probe the weak pillars before committing.

50-66

Enterprise-grade candidate. Proceed to a proof-of-value.

Two questions that override the rest

If a vendor scores Red on autonomy guardrails (Q11-Q15) or on data ownership (Q20), treat the total with caution no matter how high it is. An AI that can act without a brake, or a platform you can't leave, is a risk no detection score buys back.

HOW UNDERDEFENSE SCORES

Where UnderDefense lands on this scorecard

We built this scorecard from the questions our own customers asked during evaluation. Here is how we answer the pillars that matter most.

Pillar	UnderDefense
Detection Accuracy	96% MITRE ATT&CK coverage proven, ~99% noise reduction, detection tuned per environment
Investigation Logic	Auditable reasoning chain; correlation across identity, endpoint, cloud, SaaS; analyst override at every step
Autonomy Guardrails	Pre-authorization, asset-class scoping, kill switch, and ChatOps user verification before containment
Integration Depth	250+ integrations; layers on your existing stack — no rip-and-replace; you keep your data
Explainability & Compliance	Human-readable evidence trail; exportable for SOC 2, HIPAA, ISO 27001; full audit trail
Pricing & TCO	Published per-asset pricing; transparent 3-year TCO; data portability in the contract
AI Authenticity	Observable agent workflow; production agentic AI paired with concierge analysts; purple-team in the POV

Score us against your current setup

Bring your stack, your alert volume, and your toughest two or three questions. We'll show where agents help, where a human still decides, and what the evidence trail looks like — before any commitment.

Get a free SOC assessment → underdefense.com/contact

See it on your environment → underdefense.com/book-a-personal-demo